HỘI DOANH NGHIỆP TRẺ HÀ NỘI (HANOIBA)
CLB DOANH NHÂN CEO 1983
Số: BC-SEC-47/2026/CEO1983

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM
Độc lập - Tự do - Hạnh phúc
Hà Nội, ngày 04 tháng 11 năm 2026

TÀI LIỆU BẢO MẬT NỘI BỘ • PHỤC VỤ ĐÁNH GIÁ AN TOÀN THÔNG TIN (ATTT)

BÁO CÁO TIÊU CHUẨN LẬP TRÌNH AN TOÀN & BẢO VỆ DỮ LIỆU ZERO-TRUST 6 LỚP

DỰ ÁN: HỆ SINH THÁI NỀN TẢNG SỐ CLB DOANH NHÂN CEO 1983

(Báo cáo Thẩm định Tiêu chuẩn Code An toàn • Phòng thủ Đa tầng Sẵn sàng Quét ATTT)

Kính gửi:

- Thường trực Ban Điều Hành CLB Doanh Nhân CEO 1983 (HanoiBA);
- Hội đồng Thẩm định & Ban Kiểm Tra An Toàn Thông Tin (ATTT);
- Ban Công Nghệ & Chuyển Đổi Số.

I. CĂN CỨ VÀ NGUYÊN TẮC AN TOÀN THÔNG TIN

Báo cáo này được thiết lập nhằm rà soát và đóng dấu kỷ luật lập trình an toàn (Secure Coding) trên toàn bộ hệ thống CEO 1983 theo Văn bản 47 — Secure Coding & Data Protection (Gói Gia cố 6 Lớp Zero-Trust). Toàn bộ các rủi ro bảo mật tiềm ẩn gồm Hardcode, XSS, IDOR, Lộ lọt Dữ liệu nhạy cảm, Forged JWT, Leo thang đặc quyền (Privilege Escalation), SQL Injection và Tấn công Vũ lực (Brute-Force) đã được kiểm tra và xử lý triệt để.

KỶ LUẬT THỰC THI BẢO MẬT (OS-SEC-ZERO-TRUST-47)

Tuyệt đối cấm commit secret tĩnh vào code. Bắt buộc xác thực quyền sở hữu (IDOR check). Ép chuẩn JWT HMAC-SHA256 + constant-time comparison. Bật Trigger Write-Guard kiểm soát quyền trên PostgreSQL và khóa cứng Rate Limiting.

II. RÀ SOÁT CÁC LỚP BẢO VỆ DỮ LIỆU & KẾT QUẢ ĐÁP ỨNG TIÊU CHUẨN

Hệ thống đã thực hiện kiểm tra chi tiết từng file nguồn của dự án và xác nhận đáp ứng đầy đủ 100% các tiêu chí an toàn:

Lớp Bảo Mật	Quy Chuẩn File 47	Hiện Trạng Kỹ Thuật Đã Triển Khai	Trạng Thái
1. Cấm Tuyệt Đối Hardcode	Không để API Key, Password, Secret Key, DB URL tĩnh trong code .ts/.js.	Đồng bộ DATABASE_URL, JWT_SECRET, MINIO_*, SMTP_* tập trung 100% qua biến môi trường .env. Không có secret tĩnh trong mã nguồn.	**ĐẠT CHUẨN**
2. Chặn Rò Rỉ Dữ Liệu Nhạy Cảm	Không trả về password_hash, salt, reset_token ra client. Dùng DTO lọc.	Chuẩn hóa DTO Display-Ready trên 100% API response, bóc tách triệt để các trường mật mã trước khi trả về Frontend.	**ĐẠT CHUẨN**
3. Chống IDOR Cửa Ngõ API	Mọi API chỉnh sửa/xóa phải so khớp req.user.id === record.ownerId.	Áp dụng RolesGuard và DataScopeInterceptor trên toàn bộ các route mutating (POST/PATCH/DELETE), bảo đảm kiểm tra quyền sở hữu bản ghi.	**ĐẠT CHUẨN**
4. Chống SQL Injection	Cấm cộng chuỗi SQL. Bắt buộc Parameterized Queries ($1, $2) hoặc ORM.	Prisma Client và raw query đều truyền tham số qua mảng $1, $2. Thêm middleware Regex kiểm tra định dạng tên cột lọc.	**ĐẠT CHUẨN**

Lớp Bảo Mật	Quy Chuẩn File 47	Hiện Trạng Kỹ Thuật Đã Triển Khai	Trạng Thái
5. An Toàn Giao Diện Chống XSS	Chống XSS tự động qua React. Dùng DOMPurify nếu render HTML.	React Virtual DOM tự động escape chuỗi; toàn bộ nội dung rich text (bài đăng, tin tức) đều được khử khuẩn qua DOMPurify.	**ĐẠT CHUẨN**
6. Quản Lý Token & Auth	JWT ký bí mật riêng biệt; hạn 7 ngày; refresh token rotation; băm Bcrypt 10 rounds.	Cấu hình JwtModule với JWT_SECRET tách biệt; mã hóa mật khẩu Bcrypt salt 10 rounds; token khôi phục 32-byte ngẫu nhiên.	**ĐẠT CHUẨN**

III. ĐÁNH GIÁ 6 LỚP GIA CỐ ZERO-TRUST BẮT BUỘC

Lớp Phòng Thủ	Mục Tiêu Bảo Vệ	Hiện Trạng Kỹ Thuật Đạt Chuẩn	Đánh Giá
Lớp 1: API Gateway	Bảo vệ tầng mạng và chống tấn công từ chối dịch vụ	ThrottlerModule cấu hình 100 requests/phút; Helmet bổ sung đầy đủ security headers; CORS giới hạn chặt chẽ.	**ĐẠT CHUẨN**
Lớp 2: Authentication	Xác thực định danh người dùng an toàn	JwtAuthGuard kích hoạt; xác thực token với chữ ký bí mật; chuẩn hóa UUID v4 cho toàn bộ tài khoản.	**ĐẠT CHUẨN**
Lớp 3: RBAC & Data-Scope	Phân quyền đa cấp và kiểm soát phạm vi dữ liệu	RolesGuard xác thực vai trò hội viên; ngăn chặn việc xem, sửa hoặc xóa dữ liệu của hội viên khác.	**ĐẠT CHUẨN**
Lớp 4: Service Layer	Xử lý nghiệp vụ an toàn và bọc lỗi	ValidationPipe lọc dữ liệu đầu vào; cơ chế try-catch toàn diện; không làm lộ stack trace nội bộ ra client.	**ĐẠT CHUẨN**
Lớp 5: Database Layer	Bảo vệ tầng cơ sở dữ liệu PostgreSQL	Prisma ORM parameterized queries; Trigger Write-Guard kiểm soát quyền cập nhật; kết nối an toàn qua PgBouncer.	**ĐẠT CHUẨN**
Lớp 6: Audit & Monitoring	Ghi nhật ký kiểm toán và giám sát an ninh	Lưu vết toàn bộ giao dịch tài chính, đổi mật khẩu và thao tác quản trị; sẵn sàng tích hợp hệ thống SIEM.	**ĐẠT CHUẨN**

IV. KẾT LUẬN & PHÊ DUYỆT BẢO MẬT

Hệ sinh thái nền tảng số CLB Doanh Nhân CEO 1983 đã hoàn tất thẩm định lập trình an toàn và gia cố 6 lớp Zero-Trust, bảo đảm tính toàn vẹn và an toàn thông tin tuyệt đối, sẵn sàng tiếp nhận kiểm thử và quét ATTT chính thức.

ĐẠI DIỆN ĐƠN VỊ KỸ THUẬT
Trưởng Ban Công Nghệ & Chuyển Đổi Số

BAN KỸ THUẬT VIONE / CEO 1983

BAN ĐIỀU HÀNH CLB CEO 1983
Chủ Tịch CLB Doanh Nhân CEO 1983

NGUYỄN XUÂN THẮNG